

Security laboratory for Active Directory systems based on Samba and Windows

TIAGO F. DELGADO, Instituto Superior Técnico, Portugal

According to IT Governance, in 2023 there were 2,814 incidents involving 8,214,886,660 compromised network user accounts. With 95% of Fortune 500 companies relying on Microsoft Active Directory, securing these networks is crucial. Given the rise in cybercrime, training cybersecurity professionals in Active Directory systems requires laboratories where attacks and countermeasures can be studied extensively. However, building these Active Directory environments typically demands substantial memory, storage, and processing power, creating barriers to hands-on training.

This MSc dissertation proposes the development of two penetration testing laboratories within the GNS3 network emulator: one using Samba and the other using Microsoft AD on Windows. The choice of Samba is primarily driven by its lightweight nature. The objective is to compare these two environments in terms of resource usage and the range of supported attacks. The results indicate that Samba-based labs consume significantly fewer resources but are more limited in the range of supported attacks. To implement certain attacks in the Samba environment, it was necessary to modify the existing attack tools originally designed for Microsoft AD. The Samba lab includes common network attacks such as User Enumeration, Password Spraying, LDAP Dump, AS-REP Roasting, Kerberoasting, and NTLM Relay. The Windows lab, in addition to the previously mentioned attacks, incorporates attacks involving ACLs, GPOs, Kerberos Delegations, and forged tickets. Moreover, two lab guides were developed for Samba and Windows AD, instructing users on configuring and executing attacks. Additionally, intrusion detection rules were developed for Kerberos-based attacks.

This work was supported by Instituto de Telecomunicações and Devoteam.

CCS Concepts: • **Security and privacy** → **Systems security**; **Penetration testing**; • **Networks** → **Network protocols**.

Additional Key Words and Phrases: Cybersecurity, Network attacks, Samba, Microsoft Active Directory

ACM Reference Format:

Tiago F. Delgado. 2024. Security laboratory for Active Directory systems based on Samba and Windows. *ACM Trans. Graph.* 37, 4, Article 111 (October 2024), 10 pages. <https://doi.org/XXXXXXX.XXXXXXX>

1 Introduction

As the Internet evolved, organizations witnessed a surge in the number of connected devices within their networks. This led to the necessity of centrally managing these devices, culminating in the development of Active Directory by Microsoft in 1999. This system developed for Windows networks manages and organizes resources

within domains, making it easier to handle AD objects such as users, groups, computers, and printers. To support this functionality, AD relies on key protocols like Kerberos, NTLM, LDAP, DNS, and SMB. DNS identifies domain resources, Kerberos and NTLM handle authentication, LDAP manages authorization, and SMB grants access to shared resources.

Recent studies show that 95% of Fortune 500 companies utilize AD [Rollin 2022]. Therefore, it is important to prevent and minimize the impact of security incidents ranging from conventional unauthorized access to ransomware attacks. Evaluating the security of networks requires assessments in controlled environments where intrusion tools can be tested. This underscores the importance of creating security laboratories to build technical skills and assess the impact of attacks and countermeasures. However, a key challenge in developing these labs is the high computational demand of Windows Domain Controllers and Domain Members in Active Directory. A more resource-efficient alternative is Samba, a Linux application that emulates Active Directory.

This MSc dissertation aims to develop two Active Directory security laboratories: one based on Samba and the other on Microsoft Active Directory within the GNS3 network emulator. The primary goal is to compare these environments in terms of resource usage and range of supported attacks. The first laboratory, based on Samba, aims to leverage its lightweight nature to offer a lower-resource alternative for AD penetration testing. The second laboratory will be built using Microsoft Active Directory and will serve as a complementary platform, addressing the limitations present in the Samba environment. Given that many attack tools and techniques are designed specifically for Microsoft AD, this lab will facilitate the implementation of a wider range of attacks, that may not be fully supported in Samba. Together, these laboratories will serve as educational environments for demonstrating a range of security attacks and evaluating the effectiveness of associated countermeasures.

2 Active Directory

Active Directory (AD) is a directory service developed by Microsoft for Windows network environments. It is a centralized database that stores and manages information about an organization's resources which include computers, users, groups, file shares, and policies within a domain.

2.1 Active Directory Structure

2.1.1 Domain. A fundamental building block in AD is the Domain. An AD domain is a logical group of objects (users, computers, file shares, and other resources connected within a network) that share the same AD database which is managed by the central servers of a domain (Domain Controllers).

2.1.2 Domain Controllers. A Domain Controller (DC) is the central server of a domain that runs the Active Directory Domain Service (AD DS). It is responsible for maintaining the domain database,

Author's Contact Information: Tiago F. Delgado, Instituto Superior Técnico, Lisbon, Portugal, tiago.f.delgado@tecnico.ulisboa.pt.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

© 2024 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM 1557-7368/2024/10-ART111
<https://doi.org/XXXXXXX.XXXXXXX>

which contains all the information about domain objects, and providing Active Directory services such as authentication, authorization, and name resolution. To allow computers and users to access the database data, the Domain Controllers provide a series of services including DNS, Kerberos, LDAP, and Server Message Block (SMB).

2.1.3 Organizational Units. Organizational Units (OUs) are logical containers that serve as a fundamental building block for organizing and managing network resources within a domain [Desmond et al. 2013].

2.1.4 Trees and Forests. A domain tree is a hierarchical structure of domains within Active Directory that reflects an organization's layout [Francis 2021]. Therefore, a tree is composed of one or more domains that share a contiguous namespace, essentially forming a collection of domains arranged as subdomains of the root domain. Consider the scenario represented in Figure 1: a corporation named Polaris decided to build its first Active Directory domain named `polaris.org`. This domain will serve as the root of a domain tree, forming a hierarchical structure. If Polaris were to add domains named Europe, and Asia, then the names would be `europa.polaris.org` and `asia.polaris.org`. The entire structure, even if it contains only one domain, is known as the `polaris.org` tree [Desmond et al. 2013]. Therefore, domain trees simplify the administration of multiple domains by allowing administrators to manage resources and enforce security policies uniformly across the entire tree.

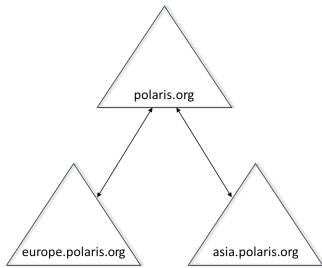


Fig. 1. Tree.

On the other hand, a forest is a collection of one or more domain trees that do not form a contiguous namespace [Alvin 2020]. Figure 2 illustrates the scenario where Polaris, the corporation of the previous example, with the domain tree `polaris.org`, acquires another corporation named Zeta with a domain tree `zeta.org` forming a forest. Therefore, forests facilitate resource sharing and trust relationships across different domains and trees, maintaining separate administration capabilities.

2.1.5 Trust Relationships. Organizations may need to share resources, such as applications, data shares, or servers. Active Directory trusts enable users in one domain to access resources in another domain, facilitating collaboration and resource sharing. Trusts can be one-way or two-way. In a one-way trust, users in the trusted domain can access resources in the trusting domain, but not vice versa. For instance, if the domain `zeta.org` has a one-way incoming trust from `polaris.org`, users in `zeta.org` can access

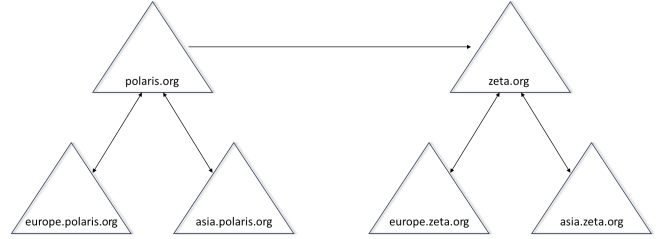


Fig. 2. Forest.

`polaris.org` resources, as represented in Figure 2. In a two-way trust, both domains trust each other, allowing mutual resource access.

3 Name Resolution

Name resolution in Active Directory ensures that devices can locate each other and access resources by translating hostnames to IP addresses. DNS serves as the primary method for this, playing an important role in locating resources like computers, services, and servers. In AD environments, DNS is essential for domain members to communicate with domain controllers for authentication, using DNS SRV records to find services such as the Kerberos Key Distribution Center and LDAP servers. Thus, DNS is essential for locating the necessary hosts and resources in an AD environment [Francis 2021].

4 Remote Procedure Call

Remote Procedure Calls (RPCs) are a crucial component of Active Directory that enables communication between several networked services and applications to communicate and execute procedures remotely as if they were local function calls. RPCs use various transport protocols, including TCP port 135 and SMB via named pipes.

In a domain, RPCs are regularly used by computers to communicate and manage services. System administrators also rely on RPCs to remotely manage directory objects, such as user accounts and group policies. This is done using RPC interfaces that define specific functions to allow remote programs to interact with different services on the computer. Moreover, it is important to highlight the Directory Replication Service Remote (DRSR) protocol. Active Directory relies on RPCs to synchronize data between domain controllers. Changes made on one domain controller are propagated to others through RPC, ensuring consistency across the directory. A key protocol involved in this process is the DRSR, which domain controllers use to replicate data. However, this protocol can also be exploited by an attacker with sufficient privileges to replicate domain user credentials, as will be discussed in section 9.3.

5 Authentication

Authentication is the foundation of a secure network, particularly in Active Directory environments where it verifies user identities and controls access through Domain Controllers. This dissertation focuses on two key authentication protocols used in Active Directory: Kerberos and NTLM. While Kerberos is known for its robust

security features and its effectiveness in providing secure authentication within network environments, NTLM is considered outdated because it lacks crucial security features.

5.1 Kerberos

Kerberos (v5) is the default authentication protocol in Active Directory, providing secure user and computer authentication across the network. It uses a ticket-based system, where the Key Distribution Center (KDC), typically a Domain Controller, issues time-limited and encrypted tickets to clients. These tickets allow access to network resources without repeatedly requiring credentials, serving as proof of authentication. Additionally, the protocol requires accurate time synchronization between the KDC, clients, and services to prevent replay attacks and ensure ticket freshness. This is achieved by using timestamps in the messages exchanged. Therefore, the clocks of all participants must be synchronized, and can not differ by more than five minutes in either direction. Moreover, Kerberos employs strong encryption, like AES and Camellia, and message integrity checks through HMAC with algorithms such as MD5 and SHA-2, ensuring confidentiality and integrity.

5.1.1 Kerberos Components.

Transport Layer. In the transport layer, data is sent in clear text using UDP or TCP as the transport protocol. This reinforces the importance of Kerberos to provide encryption over an insecure network. By default, Kerberos uses port 88 TCP or UDP.

Agents. During the authentication process, the agents involved are the following:

- (1) The client or user who wants to access the service
- (2) The Access Point (Application Server), which offers the service the user wants to access.
- (3) The Key Distribution Center (KDC), a centralized server installed in the Domain Controller (DC) responsible for distributing tickets and authenticating users. It is also known as krbtgt.

Tickets. Instead of sending clear plain-text passwords over the network, Kerberos uses these encrypted tickets to prove the identity of end participants and to establish a short-lived encryption key that both parties can share for secure communication (Session key and Service session key) [Garman 2003]. There are two types of tickets issued by the KDC:

- Ticket Granting Ticket (TGT) - ticket submitted to the KDC to obtain a TGS. It is encrypted with the KDC key.
- Ticket Granting Service (TGS) - ticket submitted to a service to request access to its resources. It is encrypted with a corresponding service key.

Privileged Attribute Certificate. The Privileged Attribute Certificate (PAC) is an authorization data structure included in Kerberos tickets, containing user profile information. This structure is generated by the KDC and signed to ensure integrity and authenticity when a user authenticates to a domain. When a user authenticates to a service using Kerberos tickets, the service can use the PAC to verify the authorization level without contacting the DC to ask for that information. To verify a PAC, the service only needs to confirm

the signature without verifying the permissions included in the PAC [Garman 2003] [Microsoft 2023].

Pre-authentication. Pre-authentication is an optional Kerberos security feature requiring users to prove their identity before the Key Distribution Center (KDC) issues a ticket. This is done by encrypting a timestamp with the user key. Without pre-authentication, attackers could exploit the system for password-guessing attacks, as the KDC cannot verify the client's identity [Neuman et al. 2005].

5.1.2 Authentication process.

KRB_AS_REQ. The first action the user needs to perform is to send a KRB_AS_REQ message to the Authentication Server in order to get the TGT, as seen in Figure 3.

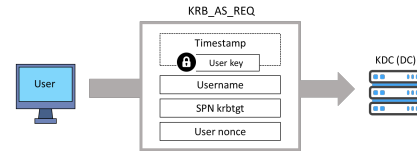


Fig. 3. KRB_AS_REQ message.

The message includes:

- The name of the user being authenticated.
- A pre-authentication timestamp encrypted with the user key.
- The SPN of the KDC (krbtgt).
- A Nonce to prevent replay attacks.
- A list of supported cryptographic algorithms supported by the user.

KRB_AS_REP. When the AS receives the AS_REQ request, it attempts to locate the account linked to the username specified in the request. Then, the AS extracts the key from the client's account and decrypts the pre-authentication timestamp. If the client's key is the same as the client key used to encrypt the timestamp, the KDC will successfully decode the timestamp and verify it. The timestamp is only validated if the time difference between the decrypted timestamp and the one generated on the domain controller is within 5 minutes. If successful, a session key is generated for subsequent client-KDC communications and the AS responds with the AS_REP message, as shown in Figure 4.

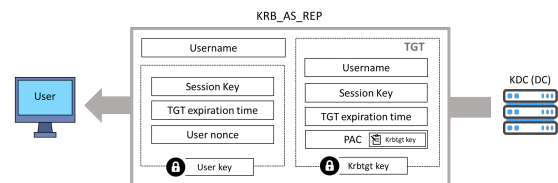


Fig. 4. KRB_AS_REP message.

The message contains the following fields:

- Username.
- Session Key, TGT expiration date, and Nonce encrypted with user's key.

- TGT encrypted with KDC key which includes the Username, Session Key, TGT expiration date, and PAC with user's privileges signed by the KDC.

After completing the process, the user will already have a TGT, which can be used to request TGS and access domain services related to Kerberos.

KRB_TGS_REQ. To request a TGS that allows the user to access services in a specific AP, the user needs to send a KRB_TGS_REQ message, as depicted in Figure 5.

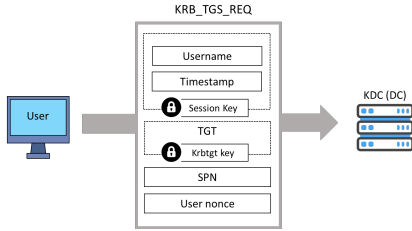


Fig. 5. KRB_TGS_REQ message.

The message includes:

- Username and Timestamp encrypted with the session key.
- TGT encrypted with KDC key.
- SPN of the requested service.
- Nonce different from the ones used in previous messages.

KRB_TGS_REP. Upon receiving the KRB_TGS_REQ, the KDC decrypts the TGT using its key, extracts the session key, validates the pre-authentication timestamp with the session key, and generates a TGS session key for subsequent client-AP communications. This new key facilitates mutual authentication between the client and the target server hosting the requested service. The session key in the TGT must match the one used on the client side for timestamp encryption. If timestamp validation succeeds, the KDC initiates the creation of the KRB_TGS_REP message, as seen in Figure 6.

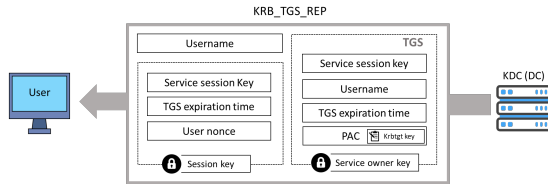


Fig. 6. KRB_TGS_REP message.

The message includes:

- Username.
- TGS encrypted with the service key which includes the Service session key, Username, and Expiration date from TGS.
- Service session key, Expiration date from TGS, PAC with user's privileges signed by the KDC, and Nonce encrypted with the session key.

KRB_AP_REQ. Upon receiving the KRB_TGS_REP, the client validates the pre-authentication timestamp using the session key, and extracts the TGS session key, but can't decrypt the TGS server data due to the unknown service key. Then, the client sends a KRB_AP_REQ message to authenticate itself to the service, as illustrated in Figure 7.

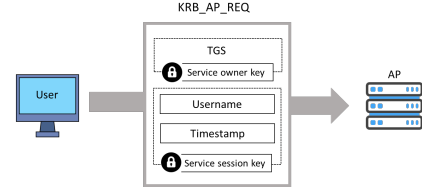


Fig. 7. KRB_AP_REQ message.

The message includes:

- TGS encrypted with the service key.
- User name and Timestamp encrypted with the Service session key.

KRB_AP_REP. Upon receiving the KRB_AP_REQ message, the server decrypts the TGS server data using its key, extracts the service session key and the PAC, and validates the pre-authentication timestamp using the service session key. Successful validation leads to the service authenticating the account. Optionally, if the access point is configured to verify the user's PAC information, the service sends the user's PAC information to the KDC to verify the signature, ensuring that the client didn't modify the data inside the PAC. If the authentication is successful, with correct permissions, the user can access the service. If mutual authentication is necessary, the access point responds with a KRB_AP_REP message to the user.

5.2 NTLM

NTLM is an older authentication protocol primarily used in Windows-based systems as a fallback when Kerberos is unavailable or unsupported. Despite being less secure than Kerberos, NTLM remains in use for backward compatibility. NTLM is encapsulated in protocols like SMB, typically using TCP port 445. As represented in Figure 8, its authentication process involves a challenge-response mechanism: the client requests authentication, the server sends a challenge (random number), the client encrypts it with the user's password hash and sends the response. The server forwards this to the Domain Controller, which verifies it. If valid, the user is authenticated, and access is granted.

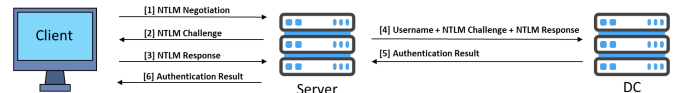


Fig. 8. NTLM scheme

The NTLM authentication process only verifies the identity of the client, thus it is vulnerable to man-in-the-middle attacks. To

mitigate this, SMB Signing can be enabled. SMB Signing adds an AES-encrypted signature to each SMB message which helps prevent such attacks by allowing recipients to verify both the content and the sender's identity. If the content doesn't match the signature, the message is discarded, protecting against tampering.

6 Lightweight Directory Access Protocol

LDAP is a directory protocol used to manage and access information stored in a directory.

While Kerberos or NTLM handles the initial authentication ensuring secure verification of user identities, LDAP comes into play for retrieving directory information for authorization purposes. After a user is authenticated using Kerberos or NTLM, LDAP is commonly used to access the directory to retrieve additional information about the user, such as group memberships, access permissions, and other attributes. These protocols work together to provide authentication and authorization in AD environments.

7 Server Message Block

SMB (Server Message Block) is a client-server network protocol used for sharing files, printers, and other resources on a network [IBM 2024]. It typically runs over TCP port 445 but can also use NetBIOS over UDP and TCP [Vazquez 2019]. An important security feature of this protocol is SMB Signing, as already explained in section 5.2. This helps ensure that the message has not been tampered with and verifies the sender's identity, offering protection against man-in-the-middle attacks by discarding any messages with mismatched signatures.

8 Samba

According to the official website, Samba is an open-source software suite that facilitates interoperability between Unix/Linux operating systems and Windows. It allows secure, stable, and fast file and print services using the SMB/CIFS protocol, and it plays an important role in integrating Linux/Unix servers and desktops into Active Directory environments, functioning either as a Domain Controller or a regular Domain Member [Samba 2024]. Developed in 1991 by reverse-engineering the SMB protocol, Samba laid the foundation for smooth integration between these systems. In this dissertation, Samba is chosen for its lightweight nature, making it a more resource-efficient alternative compared to heavier solutions like Microsoft AD.

9 Active Directory Attacks

In Active Directory environments, the success in infiltrating and compromising the system follows a strategic process divided into three main phases: Reconnaissance, Movement, and Persistence. Attackers first gather information to understand the network's structure and vulnerabilities. Next, they exploit these weaknesses for lateral movement across the network. Finally, they establish a persistent foothold to maintain access.

In this MSc dissertation, various Reconnaissance techniques such as port scanning and DNS and DHCP reconnaissance, are explored. During the Lateral Movement phase, several attacks are addressed, including Pre-authentication brute force, LDAP Dump, AS-REP

Roasting, Kerberoasting, NTLM Relay, and ACL and GPO abuses. For the Persistence phase, the Golden Ticket attack is also explored. However, this extended abstract will focus specifically on DNS reconnaissance, AS-REP Roasting, and the Golden Ticket attack.

9.1 Reconnaissance

As explained in section 3, Active Directory Domain Services (AD DS) depend on DNS SRV resource records to locate DCs. These records can be queried to discover the location of various servers, including the LDAP servers, and the Kerberos KDC, as illustrated in Figure 9. This information is crucial as these services typically run directly on DCs. However, to query the DNS records, it is required to know the domain name and which nameservers to query. Typically, this information is transmitted via DHCP offers. If necessary, a port scan on the network can be conducted to locate the nameservers by searching for DNS ports 53/TCP and 53/UDP.

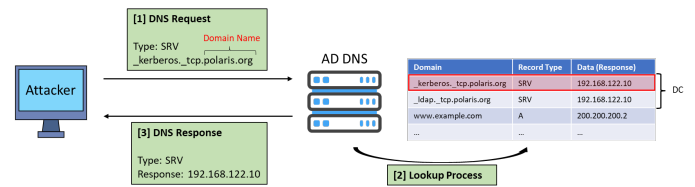


Fig. 9. DNS reconnaissance

9.2 Movement

AS-REP roasting is an attack that targets user accounts in an AD domain that have Kerberos pre-authentication disabled. Normally, pre-authentication requires users to prove their identity before receiving a Ticket Granting Ticket (TGT) from the Key Distribution Center (KDC). However, when pre-authentication is disabled, attackers can impersonate a user by sending an AS REQ message and receiving an AS REP message, which contains data encrypted with the user's password hash. Attackers can then crack this hash offline, especially when weaker encryption like RC4 is used. This technique avoids triggering account lockouts and can be executed using tools like Rubeus [Rubeus 2021], Kerbrute [Ronnie and Alex 2019], or Impacket [Impacket 2015].

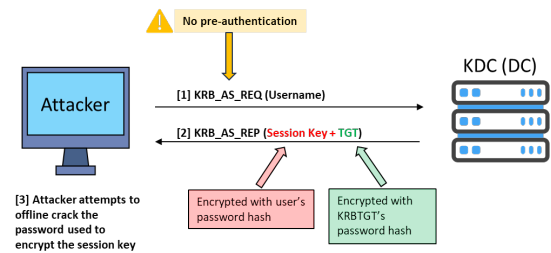


Fig. 10. AS-REP roasting

9.3 Persistence

A Golden Ticket refers to a forged Kerberos Ticket Granting Ticket (TGT) associated with the `krbtgt` account. For that purpose an attacker tries to gain access to the `krbtgt` account's password hash. Usually, this is achieved by impersonating a Domain Controller, which is possible when the attacker possesses administrative credentials. By invoking the `GetNCChanges` function through the Directory Replication Service Remote (DRSR), the attacker can request the replication of user credentials. With access to the `krbtgt` account, the attacker can generate valid tickets, allowing to impersonate any user in the domain and gain unrestricted access to network resources.

Golden Ticket attacks are highly dangerous because they allow persistent privileged access to an Active Directory domain, even after the compromised account loses its privileges [Mokhtar et al. 2022]. By using tools like `Impacket's secretsdump.py` and `ticketer.py`, attackers can obtain the `krbtgt` account's password hash and forge TGTs or TGSs. This enables attackers to impersonate any user, including domain administrators, and maintain access to the network, executing commands with administrative privileges.

10 Active Directory Laboratories

Building a realistic Active Directory environment typically demands significant memory, storage, and processing power, making hands-on AD training difficult due to high resource requirements. Thus, there is a pressing need for a more efficient, cost-effective, and accessible solution for deploying AD labs. To compare the resource usage between Samba and traditional Microsoft AD environments using Windows, and to provide students and security enthusiasts with a local environment for hands-on experience with AD networks, two pen-testing laboratories were developed in the GNS3 network emulator: one based on Samba and the other on Windows. The Samba lab, using lightweight Docker containers, reduces resource consumption and focuses on common network attacks like User Enumeration, Password Spraying, and Kerberoasting. The Windows lab expands on this by including advanced AD attacks such as ACLs, GPOs, Kerberos Delegations, and forged tickets, offering broader training coverage. However in this extended abstract only the

All configuration files, setup guides, and modified files for these laboratories can be found at AD-Labs GitHub repository [Delgado 2024].

10.1 Related Work

This section presents two relevant Active Directory pen-testing laboratories: GOAD (Game of Active Directory) [GOAD 2021] and HactiveDirectory Lab [Domingues 2023]. These laboratories offer distinct approaches to simulating AD environments and analyzing their respective strengths and weaknesses help understand the advantages and disadvantages of each solution.

10.1.1 GOAD. Similar to the proposed laboratories, GOAD is a local, robust, and economical AD lab environment for penetration testing. GOAD uses VirtualBox to deploy VMs running trial versions of Windows Server and includes three domains with trust relationships and a Domain Controller in each domain. It offers a complete and wide range of attack techniques, including User

Enumeration, Password Spraying, Kerberoasting, AS-REP Roasting, NTLM Relay, and more advanced methods exploiting like ACLs, GPOs, forged tickets, and domain trusts. Because GOAD is a lab environment that operates offline due to local hosting, it avoids costs by not using cloud services and utilizing trial versions of Windows, eliminating the need for paid licenses. Nevertheless, being local has its disadvantages since increasing the number of machines leads to an increase in the requirements as well. Moreover, it requires significant resources (115GB of total disk space and 24GB RAM), making it difficult for students and enthusiasts to afford. Additionally, after the 180-day trial period, a valid Windows license is needed or the lab must be rebuilt.

10.1.2 HactiveDirectory Lab. On the other hand, the HactiveDirectory Lab is hosted on Amazon Web Services (AWS) and provides a reliable and scalable Active Directory environment without requiring resources from physical workstations such as our proposed solution and GOAD. However, it incurs a cost of approximately \$90 per month if continuously run. In terms of attacks, it supports common attack techniques such as User Enumeration, Password Spraying, AS-REP Roasting, Kerberoasting, LDAP Dump, NTLM Relay, and Golden Ticket attacks. Despite its scalability, the lab has limitations, particularly in supporting Multicast protocols like LLNMR, which complicates experiments involving attacks such as NTLM Relay that require man-in-the-middle positioning.

10.1.3 Lab Comparison: GOAD vs HactiveDirectory. In conclusion, while GOAD is a cost-effective solution that implements various misconfigurations and vulnerabilities for testing a wide range of AD attacks, it is not the most scalable solution and requires advanced hardware that is typically unavailable on standard workstations, particularly for students. On the other hand, the HactiveDirectory Lab provides a reliable and scalable cloud-based solution, making it ideal for beginners to practice fundamental attacks. However, it offers a limited number of attacks, comes with a financial cost, and has practical limitations, particularly in performing attacks that require Multicast support. Our proposed solution aims to address the drawbacks of both labs by creating a local and lightweight environment based on Samba, offering a diverse range of attacks. This solution is cost-free, resource-efficient, and, being built within the GNS3 network emulator, allows the use of any protocol without any restrictions.

10.2 Overview

This section outlines the setup of two Active Directory pen-testing laboratories: one using Samba (domain `polaris.org`) and the other using Windows Active Directory (domain `polaris.local`). Both laboratories share a common network topology as represented in Figure 11, and have the same users, IP addresses as detailed in Table 1, and vulnerabilities where applicable. However, they differ in their implementation environments and domain configurations.

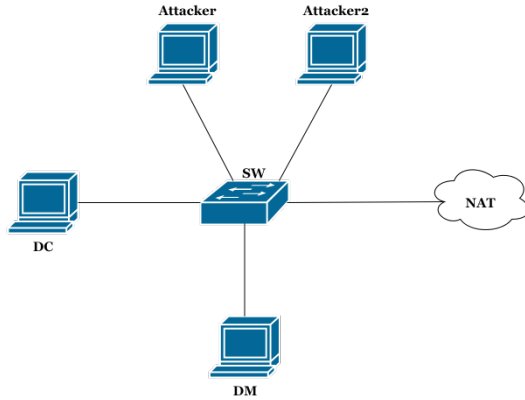


Fig. 11. Network Topology.

Component	IP Address
DC	192.168.122.10
DM	192.168.122.20
Attacker	192.168.122.50
Attacker2	192.168.122.60
NAT	192.168.122.1
SW	-----

Table 1. IP addresses configuration.

10.3 Samba Lab

10.3.1 DNS - Reconnaissance. This section demonstrates how DNS can be leveraged to discover critical network services such as LDAP servers and Kerberos Key Distribution Centers. As described in section 9.1, Active Directory Domain Services rely on DNS SRV records to locate Domain Controllers and find the location of essential services. After identifying nameservers through DHCP or port scanning, an attacker can query DNS records to retrieve valuable information about the network's services and infrastructure. As represented in Figure 12, the process begins by querying the PTR DNS records (reverse lookup) to obtain the name of the identified nameserver (DC.polaris.org). The next step is to verify if the nameserver is indeed the Domain Controller, as indicated by the DNS hostname. This can be done by querying the SRV records for LDAP and Kerberos services associated with polaris.org domain. As seen below, identifying these key services, confirms its role as the Domain Controller, as the nameserver being queried matches the server responsible for these critical services (192.168.122.10).

```

root@Attacker:~# nslookup -type=ptr 192.168.122.10 192.168.122.10
Server:      192.168.122.10
Address:     192.168.122.10#53

10.122.168.192.in-addr.arpa      name = DC.polaris.org.

root@Attacker:~# nslookup -type=svr _kerberos._tcp.polaris.org. 192.168.122.10
Server:      192.168.122.10
Address:     192.168.122.10#53

_kerberos._tcp.polaris.org      service = 0 100 88 dc.polaris.org.

root@Attacker:~# nslookup -type=svr _ldap._tcp.polaris.org. 192.168.122.10
Server:      192.168.122.10
Address:     192.168.122.10#53

_ldap._tcp.polaris.org         service = 0 100 389 dc.polaris.org.
  
```

Fig. 12. Confirming DC Identity via DNS

10.3.2 AS-REP Roasting - Movement. As described in section 9.2, the AS-REP Roasting attack exploits the disabled Kerberos pre-authentication property in a user account. This feature is typically disabled for backward compatibility with certain applications or due to misconfigurations. Similar to Password Spraying, this attack is worth attempting when some domain usernames are known, but the corresponding passwords for those accounts remain unknown.

To perform this attack the Impacket GetNPUsers.py script is used to identify users with pre-authentication disabled, leveraging the valid usernames discovered previously. If successful, the encrypted TGT is obtained which can be used to crack the password. Figure 13 illustrates the case for the user jesse.pinkman who is vulnerable to this attack.

```

(ejenv) root@Attacker:~# GetNPUsers.py polaris.org/ -request -no-pass -usersfile valid_users.txt
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
947b5a5rep5235jesse.pinkmanPOLARIS.ORG:fa23c9ee785a045de998918edaa8afcf02bc80be7f407cac6a0fa3edaaf15885d76
cb014bec01265386e0dc4484453f0078a4f329112614a2012660f60aeb70b2e43abef53b7a5a3662820715a0d6f8be16b38e1b2b2c946
05bc4f81f0a85725ecff668f4b885150c8a92959c987a4946c99e4c82fda12fe2545da88f50c0e1cc0b59c983948f23150722c1301
5f9de7284bcefae9e2eb72822b0bb4c4b7f6d2bc7618e390a7d501df112b4d06c4207343ee63615fa56e3f34758997bedce494eb
e4227628587262e3f0dffffdaac0c1630f074e424beca11bbfb5e6310e1015a96
[-] User walter.white doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User skyler.white doesn't have UF_DONT_REQUIRE_PREAUTH set
  
```

Fig. 13. Obtaining users with no pre-authentication

Figure 14 illustrates the AS-REQ messages sent from the attacker's machine and the corresponding responses. Four out of five responses contain the error `KRB5KDC_ERR_PREAUTH_REQUIRED`, indicating that pre-authentication is mandatory for those accounts. However, one response includes a legitimate AS-REP containing the encrypted TGT (jesse.pinkman).

Source	Destination	Protocol	Length	Info
192.168.122.50	192.168.122.10	KRB5	254	AS-REQ
192.168.122.10	192.168.122.50	KRB5	372	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
192.168.122.50	192.168.122.10	KRB5	254	AS-REQ
192.168.122.10	192.168.122.50	KRB5	234	AS-REP
192.168.122.50	192.168.122.10	KRB5	253	AS-REQ
192.168.122.10	192.168.122.50	KRB5	369	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
192.168.122.50	192.168.122.10	KRB5	253	AS-REQ
192.168.122.10	192.168.122.50	KRB5	369	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED

Fig. 14. Kerberos messages

With an encrypted Kerberos TGT, attackers can attempt to crack the user's password offline. Figure 15 demonstrates how john the ripper can be utilized to achieve this, successfully revealing Jesse Pinkman's password: Wang0Tang0!.


```
Impacket v0.11.0 - Copyright 2023 Fortra

[*] Brute forcing SIDs at 192.168.122.10
[*] StringBlinding mcan np:192.168.122.10[/pipe[/lsarpc]]
[*] Domain SID 15: 5-1-5-21-3510187519-2301364845-546922781
498: POLARIS/Enterprise Read-only Domain Controllers (SidTypeGroup)
500: POLARIS/Administrator (SidTypeUser)
501: POLARIS/Guest (SidTypeUser)
502: POLARIS/Vkrbtgt (SidTypeUser)
512: POLARIS/Domain Admins (SidTypeGroup)
513: POLARIS/Domain Users (SidTypeGroup)
514: POLARIS/Domain Guests (SidTypeGroup)
515: POLARIS/Domain Computers (SidTypeGroup)
516: POLARIS/Domain Controllers (SidTypeGroup)
517: POLARIS/Cert Publishers (SidTypeAlias)
518: POLARIS/Schema Admins (SidTypeGroup)
519: POLARIS/Enterprise Admins (SidTypeGroup)
520: POLARIS/Group Policy Creator Owners (SidTypeGroup)
521: POLARIS/Read-only Domain Controllers (SidTypeGroup)
522: POLARIS/Cloneable Domain Controllers (SidTypeGroup)
525: POLARIS/Protected Users (SidTypeGroup)
526: POLARIS/Key Admins (SidTypeGroup)
527: POLARIS/Enterprise Key Admins (SidTypeGroup)
535: POLARIS/IAS and IAS Servers (SidTypeAlias)
571: POLARIS/Allowed RODC Password Replication Group (SidTypeAlias)
572: POLARIS/Denied RODC Password Replication Group (SidTypeAlias)
1000: POLARIS/DCIs (SidTypeUser)
1101: POLARIS/Unsalp (SidTypeAlias)
1102: POLARIS/Unsalp (SidTypeGroup)
1109: POLARIS/saul.goodman (SidTypeUser)
1110: POLARIS/Jesse.pinkman (SidTypeUser)
1112: POLARIS/Walter.white (SidTypeUser)
1115: POLARIS/WML5 (SidTypeUser)
1114: POLARIS/Walter.white (SidTypeUser)
1115: POLARIS/hank.schrader (SidTypeUser)
1116: POLARIS/john (SidTypeUser)
```

Fig. 20. Obtaining the Domain SID

With the `krbtgt` hash and the domain SID, the forged TGT can be created using the `ticketer.py` script. Figure 21 shows the TGT being forged for an existing user in the domain, in this case, the user `skyler.white`. This golden ticket contains permissions encoded that can grant the user domain administrator privileges, however, it could have any other level of access specified during the ticket creation.

[illegible]

Fig. 21. Creating the Golden Ticket

As represented in Figure 22, with the Golden Ticket set up, the `psexec.py` script can be used to obtain a shell on the domain controller, authenticating as the `skyler.white` and gaining administrative access.

```
root@ubuntu:/home/ubuntu# psexec.py polaris.local/skyler.white@dc1.polaris.local -k -no-pass
Impact v0.11.0 - Copyright 2023 Fortra

[*] Requesting shares on dc1.polaris.local.....
[*] Found writable share ADMIN$
[*] Uploading file FLTPHLP.exe
[*] Opening SVCManager on dc1.polaris.local.....
[*] Creating service Qe6f on dc1.polaris.local.....
[*] Starting service Qe6f.....
[*] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

Fig. 22. Using the ticket to authenticate with high privileges

10.6 Resource Consumption Analysis

This MSc dissertation involved building two AD laboratories: one using Samba and the other using Microsoft AD, with the objective of evaluating and comparing the resource usage between the two setups. Figure 23 and Figure 24 summarize the results obtained from

this comparison, highlighting the differences in storage and memory consumption between the two environments, respectively.

To measure disk usage on the Linux distributions, the `df` command was used, while on Windows, the built-in storage tool was accessed via Settings > System > Storage. For evaluating RAM usage on Linux, the `free` command was utilized, whereas, on Windows, memory consumption was checked via Task Manager > Performance > Memory.

Because RAM usage has a minimal variation, a 95% confidence interval was constructed based on 10 measurements taken after powering on the appliances and allowing the system to stabilize. By using the Normal distribution to estimate the confidence interval, we can determine the range within which the true mean of the RAM usage is expected to fall with 95% certainty.

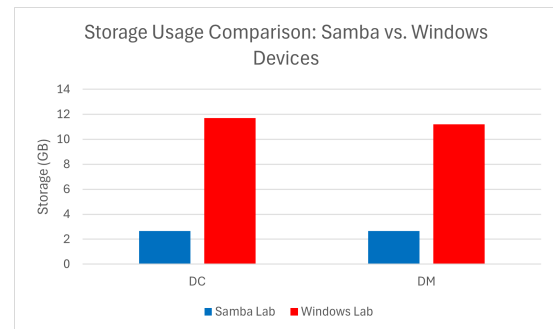


Fig. 23. Storage Usage Comparison Between Samba and Windows Devices

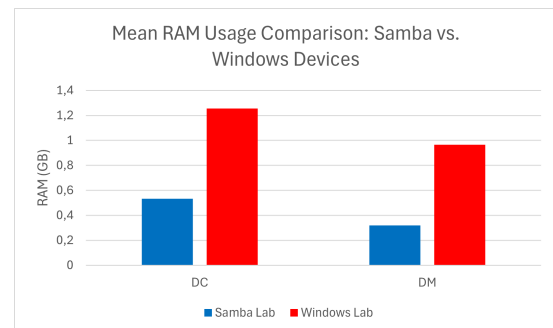


Fig. 24. RAM Usage Comparison Between Samba and Windows Devices

For the Domain Controllers, the Samba DC utilized 2.65 GB of storage and required between 543 MB and 550 MB of RAM, while the Microsoft AD DC required significantly more resources, with 11.7 GB of storage and 1.23 GB to 1.29 GB of RAM. Similar findings were observed for the Domain Member configurations, with the Samba DM consuming 2.65 GB of storage and 325 MB to 329 MB of RAM, whereas the Windows DM utilized 11.2 GB of storage and 0.91 GB to 1.02 GB of RAM.

Under the same conditions for each node, these comparisons show that Samba uses less storage and memory. This efficiency is, in part, due to the use of Docker containers, which include only

essential files for the operating system to function, resulting in a lighter Samba environment. This makes Samba a more efficient option for lightweight AD implementations.

11 Conclusions

11.1 Conclusion

Active Directory is a critical component in organizations for managing resources, and understanding its vulnerabilities is essential. This study explored various AD attack vectors, each with unique network impacts, highlighting the need for specialized labs to provide hands-on experience for cybersecurity students and professionals. As an alternative to traditional Windows-based labs, Samba was identified as a more resource-efficient and lightweight solution for implementing these environments, offering a practical and cost-effective option for AD security training.

During the course of this dissertation, two pentesting labs—one using Windows Active Directory and the other using Samba—aimed at providing hands-on training in AD security and comparing resource usage between the setups. The Samba lab, the first of its kind, presented unique challenges but successfully implemented various attacks such as User Enumeration, Password Spraying, LDAP Dump, AS-REP Roasting, Kerberoasting, and NTLM Relay. The report also includes Snort rules for detecting all these attacks, except NTLM Relay.

Building the Samba laboratory was challenging because most tools are designed for Microsoft AD environments. Samba's instability and unique configurations made certain attacks difficult to implement, as attempts to execute configurations that should have worked did not function as expected in Samba. To address these issues, the Windows laboratory was developed as a complementary setup to provide a reference for resource consumption and to execute additional attacks that are difficult or impossible to perform in Samba. The Windows lab not only covers the aforementioned attacks but also delves into AD attacks related to ACLs, GPOs, Kerberos Delegations, and forged tickets, thereby improving the overall scope of the training material.

The labs were designed to simulate realistic scenarios, providing a safe environment for hands-on experience in Active Directory security. Results show that the Samba lab is more lightweight and resource-efficient than the Windows lab, making it ideal for users seeking to explore AD vulnerabilities without significant resource demands. Together, these labs serve as valuable tools for learning and improving skills in AD, particularly insecurity, covering both basic and advanced attack techniques.

11.2 Future Work

While the developed labs provide a good starting point for learning Active Directory security, there are several ways to expand and improve their scope and functionality in future iterations.

For the Samba lab, incorporating additional Kerberos-based attacks would be beneficial since these attacks rely on the Kerberos protocol rather than Samba itself. Examples of such attacks include Kerberos Delegations, Silver Tickets, and Golden Tickets. Additionally, exploring attacks related to group policies and inter-domain trusts could add value to our laboratory. These improvements may

require significant research, as many existing tools are not developed for Samba, and advanced configurations might not perform as expected.

The Windows lab could also be improved by including more attacks, particularly those targeting unpatched vulnerabilities documented in several CVEs, such as PrintNightmare (CVE-2021-34527), ZeroLogon (CVE-2020-1472), and sAMAccountName spoofing (CVE-2021-42278/CVE-2021-42287). Expanding the lab to include scenarios involving trust relationships between domains would further enrich the laboratory.

References

- A. Alvin. 2020. Forests. <https://learn.microsoft.com/en-us/windows/win32/ad/forests> Accessed 24-Jul-2024.
- T. Delgado. 2024. AD Laboratories. <https://github.com/trovoes18/Samba-Lab/tree/main> Accessed 3-Oct-2024.
- B. Desmond, J. Richards, R. Allen, and A. Lowe-Norris. 2013. *Designing, Deploying and Running Active Directory* (5 ed.). O'Reilly.
- T. Domingues. 2023. *Pentesting Labs for Web Security and Active Directory*. Master's thesis. Instituto Superior Técnico.
- D. Francis. 2021. *Design, deploy, and protect Active Directory Domain Services for Windows Server 2022* (3 ed.). Packt.
- J. Garman. 2003. *Kerberos: The Definitive Guide* (1 ed.). O'Reilly.
- GOAD. 2021. GOAD. <https://github.com/Orange-Cyberdefense/GOAD> Accessed 24-Jul-2024.
- IBM. 2024. SMB protocol. <https://www.ibm.com/docs/en/aix/7.2?topic=management-smb-protocol> Accessed 24-Jul-2024.
- Impacket. 2015. Impacket. <https://github.com/fortra/impacket/tree/master> Accessed 2-Oct-2024.
- Microsoft. 2023. [MS-PAC]: Privilege Attribute Certificate Data Structure. https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-pac/166d8064-c863-41e1-9c23-edaaa5f36962 Accessed 24-Jul-2024.
- Basem Ibrahim Mokhtar, Anca D. Jurchut, Mahmoud Said ElSayed, and Marianne A. Azer. 2022. Active Directory Attacks—Steps, Types, and Signatures. *Electronics* 11, 16 (2022). <https://doi.org/10.3390/electronics11162629>
- C. Neuman, T. Yu, S. Hartman, and K. Raeburn. 2005. *The Kerberos Network Authentication Service (V5)*. RFC 4120. IETF. <https://www.rfc-editor.org/rfc/rfc4120>
- B. Rollin. 2022. What is Active Directory? (Active Directory hacking intro). <https://www.hackthebox.com/blog/introduction-to-active-directory> Accessed 3-Oct-2024.
- F. Ronnie and F. Alex. 2019. Kerbrute. <https://github.com/ropnop/kerbrute> Accessed 24-Jul-2024.
- Rubeus. 2021. Rubeus. <https://github.com/GhostPack/Rubeus> Accessed 24-Jul-2024.
- Samba. 2024. About Samba. <https://www.samba.org/> Accessed 24-Jul-2024.
- A. Vazquez. 2019. *Prepare for the Highest Level Professional Linux Certification* (1 ed.). Apress.